

CISM Domain 4B — Incident Management Operations: Exam Essentials

Second half of Domain 4 (Incident Management, 30% of the exam). Covers tools & techniques (4B1), investigation & evaluation (4B2), containment (4B3), communications (4B4), eradication & recovery (4B5), and post-incident review (4B6).

Tools, Teams & Techniques (4B1)

- **IMT** = decision-making body; **IRT** = technical responders (often one team in smaller orgs).
- **IRT models:** central (one team), distributed (per geography/BU), coordinating (central sets standards, guides distributed teams), outsourced.
- Team roles: security steering group (strategy/budget), IS/IR manager (leads, liaises), incident handlers/investigators, IT specialists. Permanent: handlers, forensic experts. Temporary: legal, PR, HR, business reps. Some cyber insurers require notification/control over comms.

Tech	Know this
SIEM	Centralized: consolidates + normalizes + correlates logs, prioritizes, tracks to closure; needs tuning
EDR	Individual endpoints — detect suspicious behavior, investigate/respond on the device
XDR	Broader than EDR — integrates endpoints, network, cloud, email into one unified view; ML-driven
MDR	OUTSOURCED 24/7 monitoring/hunting/response — people + process, not just tech

- **Outsourcing (MDR/SOC): accountability stays with YOU.** Contracts must define SLAs (response times!), compliance duties, data ownership/privacy, incident ID alignment, review meetings, conflict resolution.

Investigation & Evaluation (4B2)

- **Event** = any occurrence (most are normal). **Incident** = event with potential/actual negative impact. **Context is everything** — compare against baselines (3 AM login is fine if the user is traveling).
- **FIRST action on a reported breach: VALIDATE the incident** — repeated exam answer.
- If legal action is being considered, the primary focus = **preserving the integrity of the evidence** (forensic techniques + chain of custody) — exam answer.
- **Forensic essentials:** never work on originals — bit-for-bit images with write-blockers, verify hashes, WORM storage prevents tampering, capture volatile memory BEFORE shutdown, document everything.

Concept	Know this
Admissibility	Evidence must be RELEVANT, MATERIAL, and COMPETENT (legally collected). Broken chain of custody = thrown out
Chain of custody	Chronological record of who handled evidence, when, why — collection to court
Best evidence	Original preferred over copies; secondary = copy

Legal hold	Protect potentially relevant documents from alteration/destruction (core of eDiscovery)
Forensics vs eDiscovery	eDiscovery GATHERS ESI (trained IT/legal staff, no deep analysis); forensics ANALYZES, recovers deleted data, preserves integrity (specialists, work on bit-for-bit copies)
Investigation types	Administrative (internal policy), Criminal (law enforcement, strictest), Civil (lawsuits/damages), Regulatory (HIPAA/GDPR), Industry (PCI DSS, best practices)
Media sanitization	NIST SP 800-88, least → most secure: CLEAR (logical overwrite) → PURGE (lab recovery infeasible, e.g., crypto-shred) → DESTROY (physical)

Containment (4B3)

- **TOP priority in a major incident: containment** — stop the bleeding before investigating root cause (exam answer). Exception: if the question stresses legal action, evidence preservation leads.
- Containment is a **risk-based decision requiring senior management approval** (with input from legal, ISM, IMT) — acting can alert the attacker.
- Activities: isolate affected systems, capture volatile memory first, enterprise password resets, update firewall/IDS rules, collect logs to scope, forensic images, scan other systems for IoCs.

Communications (4B4)

- Pre-defined plan: WHO (audiences), WHAT (detail per audience), HOW (channels — including **secure/out-of-band** if email may be compromised), WHEN (cadence). **Single source of truth** prevents conflicting messages.
- Maintain a redundant contact directory (internal + vendors, recovery sites, insurance, regulators, law enforcement).
- **Notification triggers are regulatory**: know deadlines (GDPR breach notification = **72 hours**).
- **Law enforcement contact = senior management decision ONLY** — InfoSec never contacts LE without authorization.
- Hacker modified customer data — notify **data owners FIRST** (they assess damage and coordinate corrective action; customers/regulators later per policy) — exam answer.
- Plan telecom continuity: voice/WAN/LAN backups (satellite, wireless), UPS for telecom gear.

Eradication & Recovery (4B5)

Term	Meaning (in process order)
Triage	Initial assessment and prioritization
Containment	Limit the spread — tactical, does NOT fix root cause (“tourniquet”)
Mitigation	Reduce severity / begin fix actions
Eradication	Remove incident artifacts (malware, backdoors) — “fix the faulty wiring”
Remediation	Fix the underlying cause (patch the vulnerability)

Recovery	Restore systems to normal, secure operation — only AFTER containment + eradication
-----------------	--

- **Eradication activities:** root cause analysis, remove malicious files/backdoors, patch exploited vulnerabilities, DNS sinkholing, scan for remaining IoCs, wipe & rebuild if needed, restore from CLEAN pre-incident backups.
- **Backups can hide undetected malware** — file backups made before detection may reintroduce malicious code after eradication (exam answer).
- **DO NOT RUSH recovery** — returning to “business as usual” without fixing root cause invites repeat incidents. Validate security baseline, monitor intensely for IoCs/IoAs, hunt proactively, reintroduce systems only after verification.

Post-Incident Review (4B6)

- **Primary objective: capture lessons learned to improve the process** (exam answer).
- Ask who/what/where/when/why/how; identify root cause and corrective actions; final report to senior management; update procedures; secure funding for improvements.
- Assign a **dedicated documentation role** — like protecting a burglary scene from being trampled.
- Involve **legal counsel EARLY** (attorney-client privilege, notifications, evidence retention — consult legal before discarding evidence).
- Quantifying incident cost supports budget justification and legal evidence.

Quick Self-Check (from the handout)

1. First action on reported breach? → **Validate the incident**
2. Legal action anticipated — primary focus? → **Preserve evidence integrity**
3. Top priority in a major incident? → **Containment**
4. Hacker altered customer data — notify first? → **Data owners**
5. What makes eradicating undetected malware harder? → **File backups (malware preserved in them)**
6. Primary objective of post-incident review? → **Capture lessons learned to improve the process**

Last-Minute Memory Hooks

- Validate → contain → eradicate → recover → learn
- Contain first; root cause later — unless the question says “legal,” then evidence first
- Work on copies, never originals; unbroken chain of custody or it’s inadmissible
- Senior management approves containment and calls law enforcement
- GDPR = 72 hours; data owners get the first call
- Clear < Purge < Destroy (NIST 800-88)
- Slow recovery is safe recovery — hidden backdoors punish haste